

Nachmittag 3 – Protect

Der KMU-Schutzplan mit Quick Wins

Massnahmen bewerten, priorisieren und in einen 90-Tage-Plan giessen

Dauer	50–60 Minuten (inkl. 10 Min. Ergebnisdiskussion im Plenum)
Arbeitsform	Gruppen à 3–4 Personen
Material	Dieses Arbeitsblatt; Risikoprofil aus Übung 2
NIST-CSF-Bezug	Protect: PR.AA (Identität & Zugriff), PR.AT (Awareness), PR.DS (Datensicherheit), PR.PS (Plattformsicherheit)

Lernziele

- Schutzmassnahmen nach Kosten und Risikoreduktion statt nach Bauchgefühl priorisieren.
- Quick Wins von Grossprojekten unterscheiden und einen realistischen 90-Tage-Plan erstellen.
- Massnahmen den zuvor identifizierten Top-Risiken zuordnen (Risikobezug statt Technik-Wunschliste).

Ausgangslage

Fallstudie: Muster Metallbau AG (fiktives KMU, 45 Mitarbeitende)

Die Muster Metallbau AG begleitet Sie durch alle Übungen dieses Workshops. Details siehe Steckbrief aus Nachmittag 1 – hier die Kurzfassung:

- Branche & Tätigkeit: Metallbau und Montage – Fertigung in eigener Werkhalle plus Projektgeschäft bei Kunden vor Ort. Zusätzlich kleiner Webshop für Ersatzteile (extern gehostet).
- Mitarbeitende: 45 (30 Produktion/Montage, 15 Büro: Verkauf, Einkauf, Buchhaltung, Planung/CAD, Geschäftsleitung). Keine eigene IT-Stelle.
- IT-Landschaft: Microsoft 365 (E-Mail, Teams, SharePoint), lokales ERP-System (Aufträge, Lager, Fakturierung), 4 CAD-Arbeitsplätze, Dateiserver im Serverraum, ca. 20 Notebooks/PCs, 10 Firmen-Smartphones, WLAN für Büro und Werkhalle (ein gemeinsames Netz).
- IT-Betreuung: externer IT-Dienstleister „TechPartner GmbH“ mit Pauschalvertrag (8 Stunden/Monat, Reaktionszeit „best effort“).
- Sicherheits-Ausgangslage: keine dokumentierten Richtlinien, kein MFA, alle Büro-Nutzer sind lokale Administratoren, Backup läuft nachts auf ein NAS im selben Serverraum (kein Restore-Test bekannt), Patching „wenn Zeit ist“.

Rahmenbedingungen: Die Geschäftsleitung hat – als Ergebnis der Risikoanalyse aus Nachmittag 2 – ein Budget von CHF 15 000 für die nächsten 90 Tage freigegeben, plus maximal 2 zusätzliche Stunden pro Monat beim IT-Dienstleister. Die Top-Risiken waren: S1 Ransomware (inkl. Backup), S2 Zahlungsbetrug, S3 Kontoübernahme M365.

Aufgabe A – Massnahmen bewerten (ca. 20 Min.)

Bewerten Sie jede Massnahme aus dem Katalog: Kosten (€ = unter CHF 1 000, €€ = 1 000–5 000, €€€ = über 5 000; jeweils inkl. Arbeitsaufwand im ersten Jahr) und Wirkung auf die Top-Risiken (0 = keine, 1 = spürbar, 2 = stark). Tragen Sie zudem ein, welches Szenario (S1–S3) die Massnahme primär entschärft.

Nr.	Massnahme	Kosten (€/€€/€€€)	Wirkung (0–2)	Entschärft primär
M1	MFA (Multi-Faktor-Authentifizierung) für alle M365-Konten und Fernzugriffe aktivieren			
M2	Lokale Admin-Rechte der Büro-Nutzer entfernen; separate Admin-Konten für TechPartner			
M3	Backup nach 3-2-1-Regel umbauen (zusätzliche Kopie offline/ausser Haus) inkl. erster Restore-Test			
M4	Vier-Augen-Prinzip für Zahlungen ab CHF 5 000 einführen (organisatorisch, mit Bank konfigurieren)			
M5	Automatisches Patching für Windows, M365-Apps und Browser aktivieren; monatlicher Patch-Bericht von TechPartner			
M6	Festplattenverschlüsselung (BitLocker) auf allen Notebooks aktivieren			
M7	Security-Awareness-Programm: Kurzschulung für alle plus vierteljährliche Phishing-Übung			
M8	E-Mail-Schutz härten: SPF, DKIM, DMARC einrichten; Warnbanner bei externen Absendern			
M9	Passwort-Manager für das Büro-Team einführen; Passwort-Richtlinie erlassen			
M10	Netz trennen: Produktion/Maschinen, Büro und Gäste-WLAN in getrennte Netze			
M11	EDR (moderne Endpoint-Erkennung) auf allen PCs/Notebooks statt reinem Virenschutz			
M12	Ein-/Austrittsprozess mit Checkliste (Konten, Rechte, Geräte, Schlüssel) einführen			

Aufgabe B – Kosten-Nutzen-Matrix (ca. 10 Min.)

Ordnen Sie die Massnahmen-Nummern in die Matrix ein. Links oben stehen Ihre Quick Wins.

	Kosten tief (€)	Kosten mittel/hoch (€€/€€€)
Wirkung stark (2)	→ QUICK WINS:	→ Projekte planen:
Wirkung spürbar (1)	→ Mitnehmen:	→ Später prüfen:
Wirkung gering (0)	→ Nicht jetzt:	→ Nicht jetzt:

Aufgabe C – 90-Tage-Plan (ca. 15 Min.)

Wählen Sie Ihre Top-5-Massnahmen (Budget: CHF 15 000 beachten!). Legen Sie pro Massnahme fest: Wer treibt sie voran (GL, Büro, TechPartner), bis wann, und woran der Erfolg gemessen wird.

Prio	Massnahme (Nr. + Kurztitel)	Verantwortlich	Bis wann (Tag 30/60/90)	Erfolgskriterium (messbar)
1				
2				
3				
4				
5				

Zusatzfrage: Welche eine Massnahme würden Sie streichen, wenn das Budget halbiert würde – und warum?

Diskussionsfragen fürs Plenum

- Waren sich die Gruppen bei den Quick Wins einig? Wo nicht – und woran lag es?
- Welche Massnahmen sind primär organisatorisch statt technisch? Was heisst das für die Umsetzung?
- Was davon liesse sich in Ihrem Unternehmen innerhalb von 30 Tagen umsetzen?